Mehfil-e-Zan

Gather. Grow. Glow.

IT RULES AND REGULATIONS POLICY

Acceptable and secure use of company technology and data

Document ID	MEZ-POL-001
Document title	IT Rules and Regulations Policy
Version	1.0
Effective date	01 November 2026 (assumed)
Last review date	Not yet reviewed (first issue)
Next review date	01 November 2027
Document owner	IT Manager
Approval authority	CEO and Owner
Status	Draft for approval
Applies to	All employees, trainees, interns, contractors and anyone given access to Mehfil-e-Zan systems or data

Student project note: *This document is a student project deliverable. Retention periods, security settings and tools named here are business assumptions. Data protection, cyber crime, tax and employment laws that apply in Pakistan and Sindh must be checked, and a qualified adviser should review this policy, before a real business adopts it.*

1. Purpose and Scope

1.1 Purpose

This policy explains how everyone at Mehfil-e-Zan must use computers, the internet, email, messaging, software and data. It protects our guests' and staff members' private information, keeps our systems working, and reduces the risk of fraud, data loss and cyber attacks.

1.2 Scope

The policy covers all technology owned, leased or used for company business, including laptops, desktop computers, the POS terminal, tablets, company phones, printers, routers, WiFi, CCTV recorder, cloud accounts, email, messaging, social media accounts and websites. It also applies to personal devices used for work (Section 5.4) and to data in any form, including paper printouts.

1.3 Business assumptions

- Mehfil-e-Zan uses cloud-based tools as far as possible, such as a company email and cloud storage service, a cloud POS and a cloud backup service, so there are no in-house servers.
- The cafe holds sensitive personal data: guest names, phone numbers, membership and booking records, event photos, staff records and CCTV footage. Because our guests value privacy, this data must be handled with particular care.
- The IT Manager is responsible for technology. Support from outside vendors is managed by the IT Manager.

1.4 Related documents

Document ID	Title	Link to this policy
MEZ-SOP-001	General Office SOP	Conduct, equipment, discipline
MEZ-SOP-002	Security Measures SOP	CCTV, physical access, assets
MEZ-SOP-003	Professional Communication Ethics SOP	Email and messaging tone
MEZ-PLN-001	Business Continuity and Incident Response Plan	IT outages and data loss
MEZ-FRM-004	IT Issue Report	Reporting IT problems and incidents

2. Roles and Responsibilities

Role	Responsibilities under this policy
Owner and CEO	Approve this policy, support enforcement, and decide on serious incidents and penalties. The CEO is informed of every high and critical incident.
IT Manager	Owns this policy. Manages devices, software, accounts, network, backups and security tools. Approves and removes access, investigates incidents and keeps the asset and software registers.
Security Manager	Works with the IT Manager on CCTV, physical protection of devices and incident response. Controls access to CCTV footage with the IT Manager.

Role	Responsibilities under this policy
HR / Sales / Marketing Manager	Tells the IT Manager at once about new joiners, role changes and leavers, and applies discipline for breaches.
Finance Director	Controls access to banking, payment and accounting systems and reviews payment-related security.
Marketing Executive	Manages social media accounts securely, following Section 4.4 and the Marketing Guidelines.
Operations Officer and Supervisor	Make sure shift staff use the POS and devices correctly, and report faults and suspicious activity.
Documentation & Compliance Coordinator	Maintains version control, keeps staff acknowledgements and checks compliance during quarterly reviews.
All users	Follow this policy, keep passwords secret, lock devices, avoid risky links and downloads, protect data and report incidents immediately.

3. Acceptable Use of Company Technology

3.1 Computers and devices

- Company devices are for company business. Limited, occasional personal use is allowed during breaks if it does not affect work, security or the cafe's reputation, and does not involve illegal, adult or offensive content.
- Users must use only the account they were given. Do not log in as someone else or let others use your account.
- Lock the screen when leaving a device (Windows key + L). Devices lock automatically after 5 minutes of inactivity.
- Do not leave devices unattended in guest areas. At closing, laptops and tablets are shut down and stored in the locked cabinet.
- Do not change system settings, disable antivirus or the firewall, or connect unapproved devices such as USB drives, personal hard drives or chargers with data ports to company computers.
- The POS terminal is used only for sales and approved functions. No browsing, personal email or downloads on the POS.

3.2 Internet use

- Use the internet mainly for work, such as supplier ordering, research, delivery platforms and social media management.
- Never visit or download adult, gambling, pirated, hacking or otherwise illegal or unsafe content, or use streaming and gaming sites during working time.
- Do not use anonymising tools, VPNs that bypass controls or file-sharing services that are not approved.
- Internet activity on company devices and networks may be logged and monitored by the IT Manager for security and policy compliance. Staff are told of this in their onboarding.

3.3 Company network and guest WiFi

- There are two separate networks: a Staff Network for company devices and the POS, and a Guest WiFi for guests and members. Guests must never be given the Staff Network password.
- Staff do not connect personal phones to the Staff Network unless approved by the IT Manager. Personal phones use the guest WiFi.
- The guest WiFi is isolated from the Staff Network, protected with a WPA2 or WPA3 password, and displays a short acceptable-use notice. Its password is changed every month, and straight away if it is misused.
- The router and WiFi admin passwords are held only by the IT Manager. Routers and devices are kept updated with the latest firmware.

3.4 Official email

- Each staff member who needs email gets a company email address. Use it for all company business. Never use personal email accounts to send or receive company documents.
- Write in a professional tone, following the Professional Communication Ethics SOP. Use the standard email signature with name, position and cafe contact details.
- Do not open attachments or links you do not expect. Check the sender's address carefully (see Section 7).
- Do not send confidential data, such as guest lists, payroll or passwords, to personal email accounts or unknown recipients. Double-check recipients before sending. Use BCC when writing to many guests.
- Auto-forwarding company email to personal accounts is not allowed. Company email may be accessed by the IT Manager with the CEO's approval during an investigation or when an employee is absent.

3.5 Messaging and WhatsApp

- Guest communication on WhatsApp is done only through the cafe's official WhatsApp Business number, managed by the Sales Executive and the Supervisor on duty. Staff must not give guests their personal numbers.
- Staff coordination is done in approved company groups created and administered by the Operations Officer. Groups are used for work matters only.
- Do not share guest personal details, photos, payment details, passwords or internal documents in personal chats, large groups or social media.
- Messages must be respectful and professional. They may count as company records and may be reviewed in an investigation.
- When someone leaves, she is removed from all company groups on her last working day.

4. Passwords, Accounts and Multi-Factor Authentication

4.1 Password rules

- Passwords must be at least 12 characters long and should be a passphrase, for example three or four unrelated words with numbers or symbols. Never use names, birthdays, phone numbers or "Mehfil123".
- Use a different password for every account. Do not reuse work passwords for personal accounts.

- Store passwords only in the company-approved password manager, not on paper, sticky notes, in notes apps or in spreadsheets.
- Never share passwords, PINs or one-time codes with anyone, including the IT Manager. The IT Manager will never ask for your password. Staff who are asked for a code must treat the request as suspected phishing.
- Change a password immediately if you think it has been exposed, and report it under Section 9. Default passwords on new devices and accounts must be changed at once.
- Accounts lock after 5 failed sign-in attempts. The IT Manager unlocks them after verifying the person's identity.

4.2 Multi-factor authentication (MFA)

MFA must be turned on wherever the service offers it. It is mandatory for the following:

- Company email and cloud storage accounts for all users.
- Banking, payment, accounting and payroll systems.
- POS administrator and manager accounts, and the cloud backup service.
- Social media, website and domain accounts, and the guest-booking or membership system.
- Any remote access to company systems.

An authenticator app is preferred over SMS codes. The IT Manager holds the recovery codes in a sealed, secure place.

4.3 Accounts

- Every user has her own named account. Shared accounts are not allowed, except where a system cannot avoid them. In that case the IT Manager approves it, keeps a log and changes the password whenever a user leaves.
- Cashiers sign in to the POS with their own PIN so each sale and refund can be traced.
- Administrator rights are given only to the IT Manager, and are used only for admin tasks.

4.4 Social media and website accounts

- Accounts are created using a company email address, never a personal one, and are owned by Mehfil-e-Zan, not by the person who manages them.
- Only the Marketing Executive and the IT Manager have login access. The Owner and CEO hold recovery access.
- Posts must follow the Marketing and Brand Guidelines. Do not post guest photos without written consent.

5. Software, Licensing, Devices and Remote Access

5.1 Software installation and licensing

- Only software on the Approved Software List may be installed, and only by the IT Manager. Staff must not install, download or run other programs, browser extensions or apps on company devices.
- To request new software, send a request to the IT Manager, who checks cost, security and licensing and gets the Finance Director's approval for any purchase.
- All software must be properly licensed. Pirated or cracked software is strictly prohibited. The IT Manager keeps a software register that lists licences, renewal dates and users.

- Operating systems, apps and antivirus software are set to update automatically. Staff must restart devices when updates need it.

5.2 Company devices

- The IT Manager records every device in the asset register with its serial number, user and issue date. Users sign for devices they receive.
- Devices are used only by the person they were issued to, and are not lent, sold, repaired by outsiders or taken off the premises without IT Manager approval.
- Laptops and phones that hold company data must have a screen lock, disk encryption and remote wipe turned on.
- Report lost or stolen devices at once, within 1 hour of noticing. The IT Manager will lock or wipe them remotely and change affected passwords.

5.3 Antivirus and protection

- Every computer has antivirus software and a firewall running at all times. Staff must not turn them off.
- Removable media, such as USB drives, are not allowed unless approved by the IT Manager and scanned before use.

5.4 Personal devices (BYOD)

- Personal phones may be used to access company email and approved messaging apps only if they have a screen lock and MFA, and the IT Manager has approved it.
- Guest data, financial files and employee records must not be stored, downloaded or screenshotted on personal devices.
- If a personal phone used for work is lost, the company may remotely remove the company account and data from it. Staff must report the loss immediately.

5.5 Remote access

- Remote access is allowed only for management and office roles who have an operational need, and it needs the IT Manager's approval.
- Use only company-approved tools, with MFA, and a device with up-to-date antivirus. Do not use public or shared computers.
- Avoid public WiFi. If it is unavoidable, use the company VPN or a personal mobile hotspot.
- Do not leave remote sessions open, and do not let family or friends view or use company systems. Remote access logs may be reviewed.

6. Data Management

6.1 Data classification

Class	Examples	Handling rule
Confidential	Guest and member personal data, staff records, payroll, bank details, passwords, CCTV footage, contracts	Access by named roles only. Stored in approved, access-controlled locations. Never sent to personal accounts. Encrypted when stored on portable devices.

Class	Examples	Handling rule
Internal	SOPs, sales reports, supplier lists, event plans, internal memos	Shared within the team. Not published or sent outside without approval.
Public	Menu, brand logo, website and published social media posts	May be shared freely once approved by the Marketing Executive.

6.2 Access permissions

Access follows the "least privilege" rule: each person gets only the access needed for her job. The IT Manager grants access after a written request from the department manager, and reviews all access rights every quarter.

Role	Systems and data access
Owner and CEO	Read access to all reports. Admin recovery access to critical accounts.
IT Manager	Administrator access to systems and network. No access to payroll or HR content unless needed for support.
Finance Director	Accounting, banking, payroll and POS sales reports.
HR / Sales / Marketing Manager	HR records, sales and membership data, CRM and marketing tools.
Sales and Marketing Executives	CRM, membership and event booking data (sales), and social media and content tools (marketing). No finance or HR files.
Operations Officer and Supervisor	POS, rosters, inventory and daily operations reports. Basic guest booking data.
Security Manager	CCTV system and security logs, with IT Manager supervision.
Documentation & Compliance Coordinator	Read and edit access to the policy and document register folders.
Frontline staff	Own POS PIN and shift tools only.

6.3 Storage and sharing

- Company files are stored only in the approved cloud storage, in folders organised by department. They are not stored on desktops, personal drives or personal cloud accounts.
- Share files using access-controlled links to named people, not "anyone with the link". Remove access when the task ends.
- Do not print confidential data unless necessary. Collect printouts at once. Shred or securely dispose of them when finished.
- Guest photos and event images are stored in a restricted folder and are used only with written consent. Consent forms are kept with the Marketing Executive.
- Card numbers and card security codes must never be written down or stored. Payments go through the approved POS and payment provider only.

6.4 Privacy of personal data

- Collect only the personal data needed, such as a guest's name and phone number for a booking or membership, and tell guests how it will be used.

- Use data only for the purpose it was collected for. Never sell, share or use guest data to market other businesses.
- Do not look up, copy or discuss guest or colleague information without a work reason. Misuse of personal data is a serious breach.
- Guests and staff may ask to see or correct their data or ask for it to be deleted. Pass such requests to the IT Manager and the HR / Sales / Marketing Manager within 1 working day.
- CCTV footage is handled under the Security Measures SOP. It is never shared or posted on social media, and may only be given to authorities with the CEO's approval.

6.5 Backup and recovery

Item	Rule
What is backed up	Cloud storage, POS and sales data, membership and booking records, accounting data, HR files and the policy library.
Frequency	Automatic daily backups. A full backup every week.
Method	The 3-2-1 rule: 3 copies of data, on 2 different types of storage, with 1 copy off-site in the cloud. Backups are encrypted.
Testing	The IT Manager tests restoring data each month and records the result.
Recovery targets (assumed)	POS and email restored within 4 hours. Other systems within 1 working day. See the Business Continuity Plan.
Responsibility	IT Manager. Failed backups must be fixed within 1 working day and reported to the CEO if not.

6.6 Data retention and disposal

The retention periods below are assumptions and must be confirmed against applicable law.

Data	Keep for	Then
Guest booking and membership records	While the membership is active, plus 12 months	Delete securely
Marketing consent forms and event photos	As long as consent applies, or until withdrawn	Delete or remove from use
CCTV footage	30 days, unless needed for an incident	Overwritten automatically
Financial and tax records	6 years	Archive, then shred or delete
Employee records	Length of employment plus 3 years	Delete securely
Company email	2 years	Archive or delete
Policies and SOPs (old versions)	5 years after being replaced	Archive

Before a device is reused, sold or thrown away, the IT Manager wipes it securely. Paper records are shredded.

7. Phishing and Malware Prevention

7.1 Spotting phishing

Phishing messages try to trick you into giving away passwords, money or data. Be careful with any message that:

- Creates urgency or fear, such as "your account will be closed" or "pay today".
- Asks for a password, OTP, PIN, card number or bank details.
- Comes from an unknown sender or from an address that is slightly different from the real one.
- Contains an unexpected link, QR code or attachment, or asks you to change bank details for a supplier.
- Claims to be the CEO, the Owner, a delivery platform or a bank, and asks for gift cards, transfers or secrecy.

7.2 What to do

1. Do not click, open, reply, scan or forward the message.
2. Take a screenshot if you can, and report it to the IT Manager straight away using the IT Issue Report (MEZ-FRM-004) or a call.
3. If you clicked a link or entered a password, tell the IT Manager immediately and do not wait. Quick reporting limits the damage and is never penalised.
4. The IT Manager checks the threat, changes passwords, warns the team if needed and deletes the message.

7.3 Payment and bank safety

- Any request to change a supplier's bank details, or an unusual payment request, must be confirmed by phone, using a number from the Finance Director's records, before payment. No payment is made on the basis of an email or message alone.

7.4 Malware prevention

- Keep antivirus and updates on. Do not download files from untrusted sources or attach unknown devices.
- If a device behaves oddly, shows pop-ups, locks files or displays a ransom message, disconnect it from WiFi and the network, do not delete anything, and call the IT Manager at once.

7.5 Awareness and training

- All staff receive IT security training when they join and then once every year.
- The IT Manager sends a short security tip every month, and may run a simulated phishing test twice a year. Results are used for learning, not punishment.

8. Monitoring and Compliance

- The company may monitor its systems, email, internet use and network traffic to protect security and ensure policy compliance. Monitoring is limited to business purposes and is carried out only by the IT Manager or a person authorised by the CEO.
- Staff should not expect privacy in company systems or accounts. Private messages on personal devices are not monitored.

- The IT Manager reviews user access quarterly, checks software and asset registers every six months, and reports to the CEO.
- A breach of this policy may lead to disciplinary action under Section 7 of the General Office SOP (MEZ-SOP-001), including dismissal and legal action in serious cases.

9. Incident Reporting and Escalation

9.1 What to report

Report any actual or suspected event that could harm company systems or data, for example a lost or stolen device, a phishing click, a virus, unauthorised access, a data leak, a WiFi or POS failure, a suspicious email, or a password shared by mistake.

9.2 How to report

- Tell the IT Manager immediately by phone, and in any case within 1 hour of noticing. If she cannot be reached, tell the Supervisor or CEO.
- Complete the IT Issue Report (MEZ-FRM-004) as soon as possible after calling. Include the time, what happened, devices and data involved, and what you did.
- Do not try to investigate, delete evidence or hide the incident. Do not discuss it outside the response team.

9.3 Severity and response times

Severity	Examples	Response start	Escalate to
Low	Single device issue, blocked spam email, forgotten password	Within 1 working day	IT Manager
Medium	Phishing click with no data entered, malware on one device, WiFi outage over 2 hours	Within 2 hours	IT Manager and Operations Officer
High	Compromised account, lost device with company data, POS failure during service, backup failure	Within 1 hour	IT Manager and CEO
Critical	Guest or staff data leak, ransomware, bank fraud, widespread outage	Immediately	CEO and Owner, plus Security Manager

9.4 Response steps

1. **Contain.** Disconnect or lock affected devices and accounts, and change passwords.
2. **Assess.** The IT Manager finds out what happened, what data or systems are affected and how serious it is.
3. **Notify.** The CEO is told of high and critical cases. If personal data of guests or staff is exposed, the CEO decides within 24 hours how and when to inform those affected, and whether to inform the police, bank or authorities under applicable law.
4. **Recover.** Remove the cause, restore data from backup and check the systems before normal work resumes, following the Business Continuity Plan.
5. **Review.** Within 5 working days the IT Manager writes a short report on the cause, impact, actions and improvements. The Documentation & Compliance Coordinator logs it and tracks follow-up actions to closure.

10. Joiners, Movers and Leavers

10.1 New joiners

- The HR / Sales / Marketing Manager sends the IT Manager a notice at least 3 working days before the start date, stating role and access needed.
- The IT Manager creates accounts, sets up MFA, issues devices and trains the new employee. The employee signs the acknowledgement of this policy on her first day.

10.2 Changes of role

- When someone changes role, her access is changed at once to match the new role, and old access is removed.

10.3 Removing access when staff leave

The HR / Sales / Marketing Manager must tell the IT Manager the same day that a resignation or dismissal is confirmed. Access is removed as follows.

Action	When	Responsible
Disable email, cloud, POS, CRM and other accounts	Dismissal: immediately. Resignation: end of last working day	IT Manager
Remove from WhatsApp groups, shared drives and calendars	Last working day	IT Manager and Operations Officer
Remove from social media, website and booking accounts, and change shared passwords	Last working day	Marketing Executive and IT Manager
Collect laptop, phone, keys, ID badge and accessories, and check against the asset register	Last working day	IT Manager and Security Manager
Transfer files and email to the manager, and set an auto-reply for 30 days	Before last working day	Employee, manager and IT Manager
Wipe returned devices and remove company data from any personal devices	Within 2 working days	IT Manager
Update the asset, software and access registers, and sign the leaver checklist	Within 2 working days	IT Manager and Documentation & Compliance Coordinator

Leavers must not keep, copy or share company data, and their duty of confidentiality continues after they leave.

11. Policy Review, Approval and Compliance

11.1 Review

This policy is reviewed every 12 months, and after any high or critical incident, major system change or relevant change in law. Changes follow the review and approval process in Section 8 of the General Office SOP, and every version is logged in the Master Document Register.

11.2 Revision history

Version	Date	Description	Author
1.0	01 Nov 2026	First issue	IT Manager

11.3 Approval

	Name and position	Signature	Date
Prepared by	[Name], IT Manager		
Reviewed by	[Name], Documentation & Compliance Coordinator		
Approved by	[Name], CEO		
Approved by	[Name], Owner		

11.4 User acknowledgement

I have read and understood the IT Rules and Regulations Policy (MEZ-POL-001, Version 1.0) and agree to follow it.

Employee name	Position	Signature	Date